Assignment 3 - Implementing and Auditing Core Cybersecurity Controls

Apply and verify multi-factor authentication, encryption, endpoint security, and incident response controls based on audit scenarios and templates.

Instructions:

In this exercise, you'll assess how a company is implementing selected **technical and operational controls** aligned with CMMC Level 2. Using the provided mock audit findings, you will:

- Identify compliance gaps
- Propose practical remediation steps
- Determine which controls can be supported by automation tools

You may refer to templates provided earlier in the course (e.g., encryption policy, IR plan, and MFA checklist).

Scenario:

A mid-sized software vendor supporting DoD logistics uses cloud systems, laptops, and mobile devices. They're preparing for CMMC Level 2 and have received a pre-assessment report highlighting the following:

- MFA is enabled on email but not on VPN access.
- Disk encryption is applied only to laptops, not mobile devices.
- Endpoint protection exists but lacks centralized visibility.
- An incident response plan exists but hasn’t been tested in 18 months.
- Monitoring is performed manually, with no automated alerting.

Questions for this assignment

Tasks:

Review the scenario and answer the following:

1. Which of the issues above is the most urgent to remediate and why?

2. List at least two benefits of automating security monitoring.

3. Describe a simple plan to extend encryption to mobile devices.

4. How should the company ensure its incident response plan remains current and actionable?

5. What specific operational control could improve visibility of endpoint activity?

Solution by the Instructor:

Tasks:

Review the scenario and answer the following:

1. Which of the issues above is the most urgent to remediate and why?

2. List at least two benefits of automating security monitoring.

3. Describe a simple plan to extend encryption to mobile devices.

4. How should the company ensure its incident response plan remains current and actionable?

5. What specific operational control could improve visibility of endpoint activity?

Sample Solution:

1. Lack of MFA on VPN access is most urgent—it exposes core systems to external threat actors.
2. Automation reduces response time and minimizes human oversight gaps.
3. Require MDM-enforced encryption policies across all BYOD and company-issued mobiles.
4. Perform tabletop simulations every 12 months and update contacts and recovery steps quarterly.
5. Deploy a centralized EDR platform with logging and alerting features.